

Investigação de um incidente de exfiltração interna

Reconstrução da narrativa do incidente a partir de uma imagem pericial (E01–E04)

CASO

Imagem ESD-USB (FAT32)

Fonte lógica · fase de investigação

METODOLOGIA

NIST SP 800-86 · ISO/IEC 27037

Dual-role: papel de investigador

ÂMBITO

Insider Threat · Exfiltração local

RNCSIRT: Segurança da Informação (exfiltração não autorizada)

2 Sumário da investigação

Investigámos um cenário de ameaça interna (insider threat): exfiltração de dados a partir de uma conta com acesso legítimo, dissimulada de atividade normal. A fonte é uma imagem pericial de um dispositivo removível, recebida de outro grupo.

Âmbito da análise

- Imagem pericial ESD-USB recebida de outro grupo, aquisição lógica (32 768 MB).
- Verificação de integridade em dois ambientes independentes (FTK Imager e Kali).
- Identificação de artefactos de exfiltração e reconstrução da narrativa do incidente.
- Avaliação dos limites da prova recolhida.

FONTE EXAMINADA

32 768 MB

Imagem lógica · FAT32 · rótulo ESD-USB

ARTEFACTOS DOCUMENTADOS

5

Vetores de exfiltração identificados

HIPÓTESE DE TRABALHO

Ameaça interna

Grau de confiança elevado; atribuição individual circunstancial

3 Metodologia e preservação da prova

Duas normas complementares

Seguimos em conjunto o NIST SP 800-86, focado em integrar técnicas forenses na resposta a incidentes, e a ISO/IEC 27037:2012, focada na recolha e preservação da prova para uso em tribunal.

Verificação de integridade inicial

Antes de examinar a imagem, verificámos que ela chegou intacta. O grupo atacante calculou os hashes na aquisição; nós recalculámo-los de forma independente, em vez de aceitar os valores do relatório.

Dois ambientes, dois cálculos, o mesmo resultado: a cadeia de custódia mantém-se.

Drive/Image Verify Results

Properties

Name

Sector count

MD5 Hash

Computed hash

Stored verification hash

Report Hash

Verify result

SHA1 Hash

Computed hash

Stored verification hash

Report Hash

Verify result

Bad Blocks List

Bad block(s) in image

Image: AFD.E01

67138864

2e7b64e3d11b777e05905dfe3c5

2e7b64e3d11b777e05905dfe3c5

2e7b64e3d11b777e05905dfe3c5

Match

38a6dacf10d9f1b4e938be9327ee9d22b09

38a6dacf10d9f1b4e938be9327ee9d22b09

38a6dacf10d9f1b4e938be9327ee9d22b09

Match

No bad blocks found in image

Imagem AFD.E01 · ewfverify (Kali)

MD5

2e7b64e3...dfe3c5

Match

SHA-1

38a6dacf...09bf95

Match

4 Triagem e ferramentas

Processámos a imagem no Autopsy (81 imagens, 3 arquivos, 608 ficheiros eliminados) e exportámos para Kali Linux em modo isolado. Entre os ficheiros eliminados, destacam-se cinco imagens renomeadas para .png sem qualquer conteúdo: ruído colocado deliberadamente para consumir tempo de análise.

Ferramentas utilizadas

FTK Imager

Cria e verifica imagens; Verify recalcula MD5/SHA-1

ewfmount / ewfverify

Monta a imagem .E01 e reverifica os hashes de forma independente

Autopsy

Extension Mismatch, Suspicious Items e Keyword Search

TSK (icat / fls)

icat extrai por inode (mesmo apagado); fls lista diretórios

binwalk

Deteta conteúdo embutido; revelou o polyglot

exiftool

Lê metadados das imagens

file

Identifica o tipo real pela assinatura de cabeçalho

foremost

Carving por assinatura, sem depender do sistema de ficheiros

strings

Extrai texto de dados binários; localizou o Main.bat

dd

Cópia byte a byte; isolou o payload pelo offset exato

base64 -d

Descodifica o registo de exfiltração ofuscado

5 Validação cruzada e scripts-isco

Redundância por carving

O foremost recuperou 285 ficheiros por assinatura, sem depender das entradas de diretório. Apenas dois são OOXML, e os hashes coincidem com os já extraídos por metadados.

```
$ foremost -i ewf1 -o carving_full
285 FILES EXTRACTED · zip:= 2
780eab38...f055654 = Autopsy/icat
885d07ca...340ae2c4411 = Autopsy/icat
```

O facto de ambas as ferramentas extraírem exatamente o mesmo conteúdo confirma a fiabilidade da análise.

Scripts-isco

- Nomes suspeitos: Credential Stealer.bat e Data Stealer.bat.
- Conteúdo real: apenas executam echo; imprimem texto, sem lógica maliciosa.
- Leitura forense: engodo para desviar a atenção do investigador.

AFO Investigation - Autopsy 4.3.1

Case View Tools Window Help

+ Add Data Source + Images/Videos Communications Geolocation Timeline Discovery Generate Report Close Case

File System Listing Table Thumbnail Summary

Data Sources
File Views
File Types
Deleted Files
File Systems (609)
As I see it
MBR File Size
Data Artifacts
Metadata (3)
Analysis Results
Extended Metadata Detected (1)
Keywords Files (1963)
Accounts
Tags
Bad Items (7)
Suspicious Items (88)
Reports

< Name	S	C	O	Modified Time	Change Time	Access Time	Created Time	Size	Flags
* COMPAT-1.MBR				2023-05-05 17:51:08 WEST	0000-00-00 00:00:00	2026-05-26 00:00:00 WEST	2023-10-31 20:53:10 WEST	7168	Uns
* COMPAT-2.MBR				2023-05-05 17:51:08 WEST	0000-00-00 00:00:00	2026-05-26 00:00:00 WEST	2023-10-31 20:53:10 WEST	6144	Uns
* COMPAT-3.MBR				2023-05-05 17:51:08 WEST	0000-00-00 00:00:00	2026-05-26 00:00:00 WEST	2023-10-31 20:53:10 WEST	28160	Uns
* COMPRE-1.MBR				2023-05-05 17:51:08 WEST	0000-00-00 00:00:00	2026-05-26 00:00:00 WEST	2023-10-31 20:53:10 WEST	80720	Uns
* CORPDS-1.MBR				2023-05-05 17:51:08 WEST	0000-00-00 00:00:00	2026-05-26 00:00:00 WEST	2023-10-31 20:53:10 WEST	1605	Uns
* CREDEX-1.MBR				2023-05-05 17:51:08 WEST	0000-00-00 00:00:00	2026-05-26 00:00:00 WEST	2023-10-31 20:53:10 WEST	2224	Uns
* CRFPTO-1.MBR				2023-05-05 17:51:08 WEST	0000-00-00 00:00:00	2026-05-26 00:00:00 WEST	2023-10-31 20:53:10 WEST	1468	Uns
* CRFTVO-2.MBR				2023-05-05 17:51:08 WEST	0000-00-00 00:00:00	2026-05-26 00:00:00 WEST	2023-10-31 20:53:10 WEST	2947	Uns
* Credential Stealer.bat			1	2026-07-02 20:06:10 WEST	0000-00-00 00:00:00	2026-07-02 20:06:10 WEST	2026-07-02 20:06:10 WEST	0	[uns]
* Credential Stealer.bat.epidownload			1	2026-07-02 20:06:28 WEST	0000-00-00 00:00:00	2026-07-02 20:06:28 WEST	2026-07-02 20:06:27 WEST	166	[uns]
DAMING-1.LDL				2023-05-05 17:51:08 WEST	0000-00-00 00:00:00	2023-10-30 23:40:00 WEST	2023-10-31 21:08:28 WEST	33160	Uns
DFSLCI-1.MBR				2023-05-05 17:51:08 WEST	0000-00-00 00:00:00	2026-05-26 00:00:00 WEST	2023-10-31 20:53:10 WEST	1685	Uns
DFSMAH-1.MBR				2023-05-05 17:51:08 WEST	0000-00-00 00:00:00	2026-05-26 00:00:00 WEST	2023-10-31 20:53:10 WEST	1514	Uns
DHFCLC-1.MBR				2023-05-05 17:51:08 WEST	0000-00-00 00:00:00	2026-05-26 00:00:00 WEST	2023-10-31 20:53:10 WEST	2189	Uns
DIRECT-1.MBR				2023-05-05 17:51:08 WEST	0000-00-00 00:00:00	2026-05-26 00:00:00 WEST	2023-10-31 20:53:10 WEST	2847	Uns
DIRECT-2.MBR				2023-05-05 17:51:08 WEST	0000-00-00 00:00:00	2026-05-26 00:00:00 WEST	2023-10-31 20:53:10 WEST	1837	Uns

How Type Application File Metadata OS Account Data Artifacts Analysis Results Context Annotations Other Occurrences

Metadata

```

Name: /ring_image/AFO.E01/Credential Stealer.bat
File Type: application/octet-stream
MIME Type: 
Size: 
File Name Allocation: Unallocated
Metadata Allocation: Unallocated
Modified: 2026-07-02 20:06:10 WEST
Accessed: 2026-07-02 00:00:00 WEST
Created: 2026-07-02 20:06:09 WEST
Changed: 0000-00-00 00:00:00
MD5: d4f4bf4e6930c0d4a80089e68d7ee
SHA1: 36d3a6d830e3c1a5d544a1a4a6a37aa4a4a63da2ca40000178633d8e8
  
```

Autopsy · Deleted Files (0 bytes) vs. fls/icat no Kali (conteúdo real)

6 Ocultação por extensão trocada

O ficheiro 474f60f4....png tem extensão de imagem, mas assinatura ZIP (50 4B 03 04) e estrutura OOXML. É uma folha de cálculo com 20 contas do domínio trhplus-demo.local, incluindo credenciais em texto claro.

Observações

- A conta osilva (Operations Manager) é a única «Disabled» entre as 20.
- O Autopsy sinaliza automaticamente: Extension Mismatch / Suspicious Items.

SHA-256	780eab38...f055654
MD5	e5be25c8...4cb07f

File	File Path	Comment	Modified Time	Changed Time	Accessed Time
474f60f4caba8dc26e7a56bacc39c18.png	/img./imagens AFD.E01/imagens/ac6/474f60f4caba8dc...		2026-06-25 18:58:40 WEST	0000-00-00 00:00:00	2026-06-25 00
Hex	Text	Application	File Metadata	OS Account	Data Artifacts
Strings	Extracted Text	Translation			
Page: 1 of 1 Page	Matches on page: - of - Match	100%	Reset		
Users					
Username	Full Name	Department	Role	Email	Password
adm	System Administrator	IT	Administrator	adm@trhplus-demo.local	0d2NFRcDEUL7L%
adm.backup	Backup Administrator	IT	Administrator	adm.backup@trhplus-demo.local	wbj0NL#tS2Mr
lcarvalho	Luis Carvalho	Marketing	Coordinator	lcarvalho@trhplus-demo.local	2oXscpHEid7hw
afereira	Ana Ferreira	Sales	Assistant	afereira@trhplus-demo.local	2l#3@MUSOGTIL
isantos	Ines Santos	Marketing	Engineer	isantos@trhplus-demo.local	@mZy72v8TfUQ
vrocha	Joao Rocha	R&D	Coordinator	vrocha@trhplus-demo.local	Yr8th2Vb8#2
ksantos	Katia Santos	Sales	Specialist	ksantos@trhplus-demo.local	EhRIHJ95dqAS
slima	Sergio Lima	Support	Specialist	slima@trhplus-demo.local	MGLNVfnH6z7
flima	Filipe Lima	Logistics	Coordinator	flima@trhplus-demo.local	#HA13zcVAwb09
pteixeira	Pedro Teixeira	Operations	Analyst	pteixeira@trhplus-demo.local	QX@eKf0LzFPFI
nferreira	Nuno Ferreira	Marketing	Consultant	nferreira@trhplus-demo.local	AJQ#hb9@o*WKS-261
vsousa	Vasco Sousa	Logistics	Analyst	vsousa@trhplus-demo.local	Tad%NV2ikOar
osilva	Olivia Silva	Operations	Manager	osilva@trhplus-demo.local	*TOBvXcl87E WKS-426 Disabled
dpereira	Diogo Pereira	Sales	Coordinator	dpereira@trhplus-demo.local	DOWfg5WT0x2U
rcosta	Rita Costa	Sales	Specialist	rcosta@trhplus-demo.local	5q*zh%OikGD1
erodrigues	Eva Rodrigues	R&D	Specialist	erodrigues@trhplus-demo.local	q5Aq#8oP3Imu
mcarvalho	Marta Carvalho	Support	Manager	mcarvalho@trhplus-demo.local	%4p\$B4R3aa47
hsilva	Hugo Silva	IT	Specialist	hsilva@trhplus-demo.local	S9Ofx@ASzn
brocha	Bruno Rocha	Finance	Consultant	brocha@trhplus-demo.local	5f9t52Rh#7U8j
coliveira	Carla Oliveira	Logistics	Coordinator	coliveira@trhplus-demo.local	07e137@HW1aq

Autopsy · Extension Mismatch / vista hexadecimal (50 4B 03 04)

7 Ocultação por anexação (polyglot)

Documento oculto dentro de um JPEG

- É um JPEG válido que oculta um documento XLSX.
- O payload inicia-se no offset 0xBD72A.
- Ficheiro gerado por código (openpyxl), não por uma pessoa: criação e modificação no mesmo segundo.

SHA-256 (payload)

885d07ca...340ae2c4411

offset 0xBD72A · dd bs=1 skip=775978

Extração (dd): recuperámos um orçamento anual com as fórmulas ativas.

```
david@kali: ~/Desktop/export
Target File: /home/david/Desktop/export/21-474f60f4caba8dc26e7a56bacc39c18.png
MD5 Checksum: e5be25c8b4441d3e93cae981ae4cb07f
Signatures: 436

DECIMAL    HEXADECIMAL  DESCRIPTION
-----
0          0x0          Zip archive data, at least v2.0 to extract, compressed size: 149, uncompressed size: 205, name: docPro
ps/app.xml
195        0xC3         Zip archive data, at least v2.0 to extract, compressed size: 240, uncompressed size: 555, name: docPro
ps/core.xml
482        0x1E2        Zip archive data, at least v2.0 to extract, compressed size: 1552, uncompressed size: 10140, name: xl/
theme/theme1.xml

Target File: /home/david/Desktop/export/58-1107bdc49d29e521a91d172e408fea-fakepng.png
MD5 Checksum: b9cebec57114d0715b5ea89c244a7fb3
Signatures: 436

DECIMAL    HEXADECIMAL  DESCRIPTION
-----
1308312    0x13F698     MySQL MISAM compressed data file Version 7
5240435    0x4FF673     MySQL MISAM index file Version 11
17624120   0x10CEC38    JBOOT STAG header, image id: 15, timestamp 0x8F29ED1B, image size: 349464461 bytes, image JBOOT checks
um: 0x561, header JBOOT checksum: 0x751B

Target File: /home/david/Desktop/export/60-35d7fa46a5d058ab18ca95260a0ddd2e.png
MD5 Checksum: 05341776a43392124dc1f902f8d2a00a
Signatures: 436

DECIMAL    HEXADECIMAL  DESCRIPTION
-----
0          0x0          JPEG image data, JFIF standard 1.01
775978     0xBD72A      Zip archive data, at least v2.0 to extract, name: xl/_rels/workbook.xml.rels
776290     0xB0862      Zip archive data, at least v2.0 to extract, name: xl/workbook.xml

[~(david@ kali) - ~/Desktop/export]
~$
```

Payload aberto no Excel: fórmulas SUM ativas

Salvamento Automático ☐ Salvar Desfazer Refazer															
N2		=SOMA(B2:M2)													
	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O
1	Category	Jan	Feb	Mar	Apr	May	Jun	Jul	Aug	Sep	Oct	Nov	Dec	Total	
2	Rent & Facilities	€4 185	€4 171	€4 213	€4 164	€4 203	€4 189	€4 163	€4 201	€4 161	€4 194	€4 164	€4 166	€50 174	
3	Utilities	€871	€839	€657	€569	€645	€852	€804	€613	€527	€673	€827	€8 437		
4	Salaries & Wages	€28 094	€28 064	€28 282	€28 860	€28 136	€28 593	€28 658	€28 355	€28 554	€28 002	€27 998	€53 514	€365 110	
5	Employee Benefits	€4 245	€4 182	€4 153	€4 222	€4 188	€4 150	€4 274	€4 250	€4 136	€4 219	€4 206	€4 295	€50 520	
6	Marketing & Advertising	€1 611	€1 475	€1 929	€1 829	€1 948	€2 313	€1 637	€1 756	€2 197	€2 956	€3 706	€4 018	€27 375	
7	Software & IT Subscriptions	€1 933	€1 809	€1 893	€1 871	€1 868	€1 840	€1 925	€1 949	€1 844	€1 886	€1 752	€1 895	€22 465	
8	Travel & Transportation	€496	€545	€833	€889	€1 009	€1 397	€1 302	€1 409	€941	€757	€577	€821	€10 976	
9	Office Supplies	€296	€322	€355	€465	€284	€368	€391	€467	€453	€463	€329	€361	€4 553	
10	Insurance	€719	€726	€727	€715	€716	€716	€720	€721	€717	€713	€719	€8 523		
11	Maintenance & Repairs	€478	€586	€799	€655	€559	€515	€547	€305	€770	€704	€756	€714	€7 588	
12	Professional Services (Legal/Accounting)	€881	€882	€1 823	€924	€821	€1 809	€848	€839	€1 917	€819	€810	€1 842	€14 215	
13	Taxes & Licenses	€1 012	€1 070	€3 485	€1 182	€1 125	€3 579	€1 045	€1 066	€3 745	€1 017	€1 177	€4 230	€23 733	
14	Miscellaneous / Other	€290	€296	€176	€181	€229	€399	€157	€435	€308	€194	€3 115			
15	TOTAL	€45 109	€44 966	€49 325	€46 526	€45 669	€50 443	€46 857	€46 319	€50 209	€46 696	€47 169	€77 596	€596 884	
16															

binwalk · transição JPEG → ZIP no offset 0xBD72A

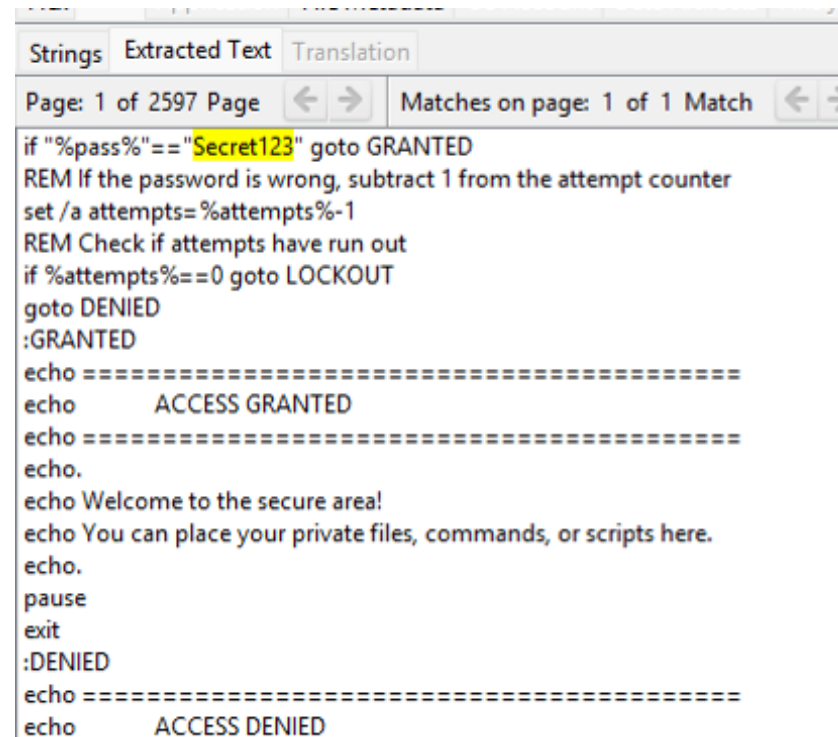
8 Ocultação e controlo de acesso

A password estava no código

- Extração: usámos o strings na imagem montada (ewfmount) para ler o espaço não-alocado.
- Descoberta: encontrámos um script apagado (offset 335 544 000) chamado Main.bat.
- O suposto bloqueio: o script simula um ecrã de autenticação com três tentativas.

```
if "%pass%"=="Secret123" goto GRANTED
```

A falsa segurança do mecanismo: qualquer pessoa com acesso de leitura ao ficheiro vê a password em texto claro.



```
Strings  Extracted Text  Translation
Page: 1 of 2597 Page  Matches on page: 1 of 1 Match
if "%pass%"=="Secret123" goto GRANTED
REM If the password is wrong, subtract 1 from the attempt counter
set /a attempts=%attempts%-1
REM Check if attempts have run out
if %attempts%==0 goto LOCKOUT
goto DENIED
:GRANTED
echo =====
echo      ACCESS GRANTED
echo =====
echo.
echo Welcome to the secure area!
echo You can place your private files, commands, or scripts here.
echo.
pause
exit
:DENIED
echo =====
echo      ACCESS DENIED
```

Autopsy · Keyword Search: reconfirma o script já recuperado

9 A prova central: registo de exfiltração

ANTES — recuperado da área não alocada

```
instructions to install imgs.txt
WzIwMjYtMDYtMjUgMTg6MTU6
MDBdIElOSVQ6IFNpbmNyb25p
emFkb3IgQXV0b23DoX...
```



DEPOIS — decodificado ao vivo

DEMONSTRAÇÃO

```
icat > base64 -d - legível em segundos
```

Log da rotina «Sincronizador Automático», datado de 2026-06-25.

Cronologia da rotina · 2026-06-25

18:15:00	18:15:05	18:15:22	18:15:27	18:15:42
INIT	SCAN	PROCESS	EXPORT	CLEANUP
rotina iniciada (PID 4892)	varre \Financeiro\	comprime e ofusca	transfere para a pen	apaga Event Logs

A intenção maliciosa está documentada no próprio log: a fase CLEANUP foi desenhada propositadamente para apagar rastros (Event Logs).

10 Limites da prova

Confirmado

- Três técnicas de dissimulação: extensão trocada, polyglot e scripts-isco.
- Exfiltração efetiva de dois artefactos OOXML (credenciais e orçamento).
- Destruição de vestígios: fase CLEANUP no log, eliminação de Event Logs.
- Validação cruzada: os mesmos resultados por várias ferramentas (Autopsy, foremost, Kali).

Por provar

- Autoria individual: a fonte é um volume de dados sem sistema operativo; faltam os registos do Windows que ligariam a ação a uma pessoa.
- O estado «Disabled» da conta osilva é dado da tabela exfiltrada, não do sistema.
- A correlação dispositivo↔máquina↔conta exigiria a estação de origem (WKS-426).

11 Conclusão

01 Validação redundante

Autopsy/icat e Kali/linha de comandos (foremost, ewfverify) chegam sempre às mesmas conclusões por abordagens diferentes.

02 Separar factos de indícios

Distinguimos o que o registo de exfiltração declara do que a imagem pericial confirma de forma independente.

03 Saber onde parar

Não apontamos um culpado direto porque a imagem não o permite. Recusar adivinhar sem provas não é uma falha da investigação, mas a garantia de um método rigoroso.

Obrigado. Perguntas?